

What Is the Federal Risk and Authorization Management Program (FedRAMP)?

The Federal Risk and Authorization Management Program (FedRAMP) is a U.S. government-wide program that provides a standardized approach for security assessment, authorization, and continuous monitoring of cloud products and services.

Cloud service providers (CSPs) wishing to provide cloud service offerings (CSOs) to the US government must demonstrate FedRAMP compliance. FedRAMP uses the National Institute of Standards and Technology (NIST) Special Publication 800 Series, and CSPs complete an independent security assessment by Third Party Assessment Organizations (3PAO) to ensure they comply with the Federal Information Security Administration Act (FISMA).

FedRAMP governing bodies include the Office of Budget and Management (OMB), the US Department of Defense (DoD), NIST, and the Federal Chief Information Officers (CIO) Council.

This is part of a series of articles about [security compliance](#).

The Importance of FedRAMP

Before FedRAMP, every US government agency carried out independent evaluations for cloud services, often resulting in expensive, inconsistent, inefficient, and redundant processes. FedRAMP provides a baseline of criteria for evaluating the security of cloud computing services, establishing standardized requirements and guidelines for all government agencies.

Although FedRAMP is intended for public-sector organizations in the US, local and state agencies also apply the FedRAMP framework in their assessments and contracts to ensure a high level of security. In the first half of 2021, An authorization program launched in 2021, StateRAMP, formally extends these cybersecurity standards to the local and state government levels, including associated providers.

FedRAMP (and StateRAMP) capabilities are also important for general enterprise use cases, often superseding the standards provided by industry-specific compliance frameworks like HIPAA, PCI, and SOC2. Private-sector organizations can apply this authorization framework to evaluate cloud service providers.

Cloud vendors with FedRAMP-authorized products commit to maintaining the strongest safeguards for their technologies and data security. These vendors must regularly evaluate their platforms to keep FedRAMP their authorization.

What Types of Businesses Need to Be FedRAMP Compliant?

A company that provides cloud computing services or software-as-a-service (SaaS) applications, and interested in working with US government agencies or organizations, must demonstrate that its systems are FedRAMP compliant. The standardized language required by FedRAMP is included in all federal contracts.

Before a cloud solution can be sold to a federal agency, it must be authorized in line with the standard. The FedRAMP authorization process requires a lot of work from an organization. Starting a FedRAMP compliance effort requires a fully built and running cloud solution and a leadership team fully committed to the FedRAMP process.

What Are the FedRAMP Governance Bodies?

Several entities at the executive branch perform FedRAMP governance, collaborating in operating and managing the program.

Here are some of the bodies involved in FedRAMP governance:

- **The Joint Authorization Board (JAB)**—the primary decision-making agency for FedRAMP governance. It consists of Chief Information Officers (CIOs) from three departments: Homeland Security (DHS), Defense (DOD), and the General Services Administration (GSA).
- **The Office of Management and Budget (OMB)**—the governing agency that issues FedRAMP policy memos that define the program's key capabilities and requirements.
- **The CIO Council**—provides information about FedRAMP to federal representatives and CIOs through events and communications between agencies.
- **The Program Management Office (PMO)**—part of GSA responsible for managing and improving the FedRAMP program, including daily operations.
- **The Department of Homeland Security (DHS)**—manages the continuous monitoring of FedRAMP, including data feed, incident response, reporting, notification, and coordination criteria.

- **The National Institute for Standards and Technology (NIST)**—provides advice on the compliance requirements of the Federal Information Security Modernization Act (FISMA). It helps establish the standards for accrediting independent assessment organizations.

What Are FedRAMP Compliance Requirements?

Achieving compliance with FedRAMP requires the cloud service provider to conduct assessments, obtain authorization, and continuously monitor its security measures. The following basic steps can help organizations achieve FedRAMP compliance and retain authorization.

FIPS 199 Assessment

NIST created the Federal Information Processing Standard (FIPS) 199 to classify cloud data according to impact level. CSPs must categorize all data they store and transmit into low, moderate, and high-impact classifications. These classifications determine the controls the organization must implement.

Initial Document Collection

FedRAMP has specified templates and documents required to prepare, authorize, and monitor an organization's security program. After completing the FIPS-199 assessment, the organization should know which documents it must present. The leadership team must collect preparatory templates and documents and identify the most relevant authorization path based on the type of data the organization handles.

Assessment by a 3PAO

A Third Party Assessment Organization (3PAO) is an accredited independent organization that conducts a cybersecurity attestation and creates a readiness assessment report (RAR). This step is optional for the agency authorization path but mandatory for the JAB path.

Plan of Action and Milestones

Creating a Plan of Action and Milestones (POA&M) is another FedRAMP requirement derived from NIST SP 800-53. The CPS or agency seeking FedRAMP authorization must implement a schedule to document security controls, including a plan of the remediation measures the organization will take to correct the security deficiencies identified during the assessment.

ATO/P-ATO and Continuous Monitoring

The CSP must choose the type of authorization it wants to obtain: an Authorization to Operate (ATO) or a Provisional Authorization to Operate (P-ATO). After obtaining the authorization, the organization must establish and implement a schedule to continuously monitor its operations and security program.

What Are the Categories of FedRAMP Certification?

FedRAMP may grant authorizations to a CSP at three impact levels: high, medium, and low. The FedRAMP impact levels estimate the scale of disruption resulting from compromising a cloud-based information system.

Low-Impact Level

The FedRAMP low-impact level sets the standard for cloud security. It applies to cloud service offerings (CSOs) where losing data availability, confidentiality, or integrity will cause minimal harm to the assets and operations of a federal agency.

Systems with FedRAMP low-impact data can have a low baseline or low-impact SaaS level. The standard low level is most relevant to a CSP that handles federal data for public consumption, comprising 125 security controls. Losing data at this level doesn't impact the agency's safety, mission, reputation, or finances.

FedRAMP's tailored baseline applies to CSPs with low-impact SaaS systems. This baseline has fewer security controls than the standard low-impact baseline-only 38—and has consolidated security documentation.

The tailored baseline allows faster, streamlined authorization processes for low-risk cloud services. Examples include project management systems, collaboration platforms, and open source code development applications.

Moderate-Impact Level

FedRAMP's moderate-impact level is common for cloud services that handle controlled, unclassified information (CUI) for federal government organizations and agencies. This level applies to CSPs that handle confidential government data, not publicly available information.

Compromises of a moderate-impact system could severely damage the operations and mission of a government agency. This damage could affect digital assets, harm individuals,

or result in financial losses. A notable example of medium-risk data is personally identifiable information (PII). The baseline for a moderate-level system is 325 security controls.

Moderate-impact systems must have controls implemented via automated mechanisms, facilitating the management of accounts and information system security. For instance, account managers should receive automatic text or email notifications of the transfer or termination of a user. CSPs must also maintain continuous monitoring of account usage.

High-Impact Level

The FedRAMP high-impact level is the security standard required for the most critical and sensitive government data. It applies to unclassified information in cloud environments.

Industries that use high-impact data include law enforcement, healthcare, and emergency services. Compromising this type of data (or the cloud systems housing it) can have catastrophic consequences for a government agency.

High-impact breaches can cause operations and information systems to shut down, resulting in heavy financial losses and derailing government investigations. Exposing this data can also threaten intellectual property and even human life.

FedRAMP and HackerOne

As a FedRAMP authorized company, HackerOne is recognized by the U.S. federal government as complying with a standardized approach to security assessment, authorization, and continuous monitoring of cloud products and services. HackerOne was the first crowdsourced security company to receive this authorization and remains the leader in this space.

All HackerOne customers, including those from the U.S. federal government sector, benefit from this recognition by protecting their cloud applications with a trusted, validated security partner.

[Learn more about HackerOne and FedRAMP](#)

Company

Leadership

Careers

Partners

Newsroom

Contact Us

Knowledge

Center

Application Security

Penetration Testing

Cloud Security

Hacking

Cybersecurity

Attacks

DevSecOps

Resources

Blog

Documentation

Leaderboard

Partner Portal

Resources

Contacted
by a
hacker? [+](#)